Checklist Único — Remediação Zero-Trust (Rede + Contas + Nuvem) — V13

Um só documento, em ordem cronológica. Siga de cima para baixo, sem pular. A ordem foi montada para que cada passo só aconteça quando o anterior tornou seguro fazê-lo.

⚠ As 4 regras que evitam refazer tudo

1. **Ordem é tudo:** Rede nova → Endpoints formatados → **só então** as contas. Mexer nas contas antes re-vaza as credenciais.
2. **Extrair credenciais GPON cedo** (Bloco 2) é o único passo irreversível. Confira duas vezes.
3. **Nunca toque nas contas a partir de um aparelho ainda sujo.**
4. NOVO **Ensaie a parte difícil do OpenWrt ANTES de cortar a fibra** (ver Bloco 0.5). Os Blocos 4–6 são o coração técnico e onde você mais pode travar.

◆ LEIA ISTO PRIMEIRO — Mapa de dificuldade (você disse não conhecer os processos)

Antes de começar, saiba onde vai gastar tempo e onde corre risco de travar. Estude esses pontos **antes** de chegar neles.

Bloco	O que é	Nível de atrito	Por quê
Bloco 4 (Flash)	Instalar OpenWrt no roteador	● **ALTO / ARRISCADO**	Flash errado "embrica" (brica) o aparelho. Procedimento muda por modelo **e revisão de hardware**.
Bloco 5 (VLANs)	Criar redes isoladas + firewall	● **ALTO**	Coração técnico. Modelo de VLAN mudou no OpenWrt moderno (DSA); muitos tutoriais antigos estão desatualizados e vão te confundir.
Bloco 2 (GPON)	Extrair SN/SLID da Vivo	▲ **MÉDIO**	O campo SLID pode estar oculto/bloqueado no firmware da operadora dependendo do modelo.
Bloco 6 (mDNS)	TV/câmera aparecerem no celular	▲ **MÉDIO**	Refletir descoberta só entre 30↔40 sem vazar pra 20 dá trabalho de ajustar.
Bloco 4 (PPPoE/MAC)	Autenticar na operadora	▲ **MÉDIO**	Fácil, mas **sensível à ordem dos sub-passos** (ver aviso dentro do bloco).
Bloco 3 (ONT)	Configurar o conversor de fibra	● **BAIXO**	Inserir SN/SLID é direto; só entender as luzes.
Bloco 9 (Formatar)	Limpar os aparelhos	● **BAIXO**	Simples, mas **destrutivo e irreversível** — cuidado.
Bloco 12 (SSH/Tokens)	GitHub/Azure	● **BAIXO p/ você**	Você já programa; só lembre de **regenerar**, não só trocar senha.

BLOCO 0 — Compras e preparação (antes de cortar a internet)

- ☐ **Roteador OpenWrt:**
- Até 400 Mbps: **TP-Link Archer C6 (V3/V4)** — *recomendado: flash direto pela web.*
- Acima de 400 Mbps: **Belkin RT3200** ou **Linksys E8450**.
- ⚠ **Evite o Xiaomi AX3200 como 1º projeto** (exige UART/telnet — console serial, soldar/cabo especial — muito mais difícil para iniciante).
- ● **CRÍTICO ANTES DE COMPRAR:** confira o **modelo + revisão de hardware exata** (ex.: `Archer C6 v3.2`, impresso na etiqueta na base do aparelho) na **tabela oficial de hardware do OpenWrt** (`openwrt.org/toh/start`). *Mesma caixa, hardware diferente = procedimento diferente.* Comprar a revisão errada é o erro nº 1 de iniciante.
- ☐ **ONT standalone:** TP-Link XZ000-G3 (porta SC/APC verde).

- ☐ **Mini UPS DC:** Marsriva KP3 ou Knup KP-TC44 (multi-tensão **9V + 12V simultâneos**).
- ☐ Num dispositivo limpo (ou celular no 4G/5G), baixar:
- ☐ Imagem **OpenWrt** do modelo exato (`firmware-selector.openwrt.org`), versão **stable**.
- ☐ **ISO oficial do Windows**.
- ☐ Conferir o **sha256** dos dois arquivos contra o site oficial.
- ☐ Reserve um fim de semana. A casa fica offline durante o processo.

BLOCO 0.5 — NOVO ENSAIO A SECO (faça enquanto AINDA tem internet pela Vivo)

> **Por que este bloco existe:** os Blocos 4, 5 e 6 (flash + VLANs + firewall + mDNS) são a parte mais difícil de tudo. Aprender isso **com a casa offline e sob pressão** é receita para desastre. Faça o aprendizado aqui, num fim de semana separado, com a rede da Vivo ainda funcionando como rede de segurança.

- ☐ Com o roteador novo **fora da rede principal** (sem conectar na ONT/Vivo ainda), faça o **flash do OpenWrt** (Bloco 4, passos de flash).
- ☐ Pratique criar as **VLANs e regras de firewall** (Bloco 5) e o **mDNS** (Bloco 6) com calma. Erre, refaça, entenda.
- ☐ Para pesquisar dúvidas, use **o celular no 4G/5G** — não dependa da rede da Vivo (que você considera comprometida) para baixar nada que vá para o roteador.

> ● **HIGIENE DO ROTEADOR DE ENSAIO (não pule):** durante o ensaio o roteador novo encostou na sua rede atual (potencialmente comprometida) e recebeu configs de teste. **Antes do uso definitivo no Bloco 4**, faça uma de duas coisas:
> - **Re-flash limpo** (gravar de novo a imagem do Bloco 0, validada por sha256), OU
> - no mínimo, **"Reset to defaults"** pelo LuCI/botão físico, apagando toda a config de ensaio.
> Assim você entra no Bloco 4 com um aparelho em estado conhecido e limpo, e não arrasta lixo (ou exposição) do ambiente sujo para a rede de produção.

- ☐ ✓ Só avance para o Bloco 1 (cortar a fibra) quando o flash, as VLANs e o firewall já forem **familiares** para você **e** o roteador de ensaio estiver limpo (re-flash ou reset).

> ✦ **Nota de coerência:** este ensaio antecipa parte dos Blocos 4–6. Isso é proposital. Quando chegar lá "de verdade", você só vai **repetir** o que já treinou — agora num roteador limpo e ligado à ONT real.

BLOCO 1 — Airgap (cortar e isolar)

- ☐ Desconectar a **fibra** (cabo verde) do roteador da Vivo. Casa offline.
- ☐ Desativar o Wi-Fi de todos os dispositivos.

BLOCO 2 — Extração de identidade (PASSO IRREVERSÍVEL — faça cedo)

▲ **CUIDADO COM O APARELHO QUE VOCÊ VAI USAR AQUI.** O notebook ainda **não foi formatado** (isso só acontece no Bloco 9). Isto **não viola** a Regra nº 3 — aqui você só **lê credenciais locais offline da rede**, não toca em nenhuma conta. O risco real é baixo. Ainda assim, por higiene, o ideal é:
- usar **outro aparelho já limpo**, OU
- bootar um **Linux live USB** só para esta tarefa, OU
- no mínimo, ter **consciência de que esse .txt está num host não confiável** e tratá-lo como descartável depois (não o reaproveite após formatar).

- ☐ Conectar o computador ao roteador da Vivo **via cabo** (fibra já desconectada).
- ☐ Acessar o roteador da Vivo (`192.168.15.1`) → seção **WAN / GPON / Óptica**.
- ☐ Anotar num .txt seguro:
- ☐ **GPON Serial Number (SN)** — 4 letras + 8 hex.
- ☐ **SLID / GPON Password**.
- ☐ **MAC da porta WAN** (etiqueta do aparelho).
- ☐ ▲ **Se o SLID não aparecer / estiver bloqueado:** o nome do campo varia por modelo e às vezes o firmware da Vivo o esconde. Pesquise pelo **seu modelo exato de roteador Vivo** + "SLID" / "GPON password". Em alguns casos a senha não é exposta — descubra isso **agora**, não depois da fibra plugada na ONT nova.
- ☐ ⚠ Se a Vivo atualizar o firmware antes disso, você pode perder o acesso às credenciais. **Por isso é cedo.**
- ☐ Desligar e guardar o roteador da Vivo. Não volta para a rede.

BLOCO 3 — Configurar a ONT

- ☐ Ligar a **ONT** ao computador via cabo e acessar a interface web.
- ☐ Inserir **GPON SN** + **SLID**. Salvar.
- ☐ **Agora sim** conectar a fibra verde na ONT.
- ☐ Aguardar a luz **"PON"** estabilizar (parar de piscar e ficar fixa) = central reconheceu o equipamento. ✓

✦ É normal a casa seguir offline e a ONT ficar ligada sem roteador entre este bloco e o fim do Bloco 4. Esperado, sem problema.

BLOCO 4 — Flashing e WAN do OpenWrt

● **PASSO MAIS ARRISCADO DO DOCUMENTO.** Um flash errado embrica o roteador. Se já treinou no Bloco 0.5, aqui é só repetir — agora no roteador já limpo (re-flash/reset feito no fim do ensaio).

4.1 — Flash (pule só se já fez no ensaio E o roteador segue com a imagem limpa)

- ☐ **Flash** do OpenWrt com o arquivo do Bloco 0 (no Archer C6, upload na interface stock do fabricante).

4.2 — Acessar o LuCI e conectar a internet física *(sempre — mesmo que tenha pulado o flash)*

- ☐ Acessar o OpenWrt em `192.168.1.1` (**LuCI**, a interface web).
- ☐ Conectar a ONT na **porta WAN** do roteador.

4.3 — ▲ WAN na ORDEM CORRETA (não inverta!)

> ▲ **ATENÇÃO À ORDEM DESTES SUB-PASSOS.** A clonagem de MAC e a VLAN 10 precisam estar prontas **ANTES** de a sessão PPPoE subir. Se você discar o PPPoE primeiro, a Vivo pode registrar o MAC do roteador novo e **recusar a clonagem depois**. Faça nesta sequência exata:

- ☐ **1º — Ativar VLAN ID 10** na interface WAN.
- ☐ **2º — Clonar o MAC da Vivo** no campo de override de MAC da interface/device WAN (extraído no Bloco 2). ✦ *No OpenWrt moderno (DSA) esse campo fica nas configurações do device da WAN e o rótulo pode variar (ex.: "MAC address" / "Override MAC address") conforme a versão.*
- ☐ **3º — SÓ ENTÃO configurar o PPPoE** → usuário `cliente@cliente` / senha `cliente`.
- ☐ **4º — Testar:** confirmar que há internet antes de seguir. ✓

BLOCO 5 — Segmentação (VLANs) — coração do Zero Trust

> ● **PARTE TÉCNICA MAIS DEMORADA.** No OpenWrt moderno (pós-21.02, modelo **DSA**) a configuração de switch/VLAN mudou. **Ignore tutoriais antigos** que falam de `swconfig` /aba "Switch" — podem não se aplicar ao seu modelo. Procure guias recentes que mencionem **DSA** e **"bridge VLAN filtering"**.

VLAN	Nome	Regra de firewall
20	WORK-DEV	**REJECT total** ao tráfego local. Só Internet. (ambiente de código/Azure DevOps)
30	HOME-MAIN	Pessoal. Livre. **Pode iniciar** conexão com a 40; a 40 **não** com ela.
40	HOME-IOT	Tapo C100 + Smart TV. Internet restrita. Bloqueio local total às 20 e 30.
50	GUEST-WIFI	Visitantes. Só portas 80/443. **Client Isolation** ativado.

- ☐ VLAN 20 com **REJECT total** ao tráfego lateral (entrada e saída de outras zonas).
- ☐ VLAN 30 criada.
- ☐ VLAN 40 criada e isolada — atenção à regra **direcional**: 30→40 permitido, 40→30 bloqueado.
- ☐ VLAN 50 com **Client Isolation** (um visitante não enxerga o outro).

✦ **Conceito-chave que pode te travar:** "30 pode iniciar com 40, mas 40 não com 30" é uma regra de firewall **stateful direcional** (permite a conexão de saída e suas respostas, mas bloqueia conexões iniciadas no sentido oposto). Vale entender isso antes, porque é o tipo de regra que mais confunde iniciantes.

BLOCO 6 — mDNS Repeater (o "pulo do gato")

▲ Costuma dar trabalho até a TV/câmera aparecerem no celular. Reserve paciência.

- ☐ Instalar pacote `umdns` ou `avahi-daemon`.
- ☐ Refletir descoberta **estritamente entre VLAN 30 e 40**.
- ☐ ● **Garantir que a VLAN 20 (trabalho) fique INVISÍVEL** a esse tráfego de descoberta. Esse é o ponto que não pode falhar — se a 20 vazar aqui, o Zero Trust foi quebrado. *(Este ponto é validado no Bloco 8.)*

BLOCO 7 — Energia (Mini UPS DC)

- ☐ Ligar o Mini UPS na tomada (220V).
- ☐ Saída DC (9V/12V) → **ONT**.
- ☐ Saída DC 12V → **roteador**.
- ☐ **Teste de autonomia:** tirar o UPS da tomada; a internet deve continuar (alvo: 4–6h). ✓

BLOCO 8 — Teste de isolamento da rede (validação final + 1º backup)

- ☐ De um aparelho na **VLAN 40**, tentar acessar (ping/SSH) um aparelho na **VLAN 20**.
- ☐ ● **Tem que FALHAR.** Se falhar, o Zero Trust está funcionando. ✓
- ☐ Testar a regra **direcional**: de um aparelho na **VLAN 30**, alcançar a **VLAN 40** (deve **funcionar**); o contrário, 40→30 (deve **falhar**).
- ☐ Testar **VLAN 50 → qualquer** (deve **falhar**, exceto saída para a internet nas portas 80/443).
- ☐ ● **Validar a invisibilidade do mDNS (Bloco 6):** com um aparelho na **VLAN 20**, confirmar que ele **não** descobre/enxerga a TV nem a câmera (que estão na 40). Nenhum dispositivo da 40 deve aparecer para a 20. *Se aparecer, o reflector está vazando para a zona de trabalho — volte ao Bloco 6.*
- ☐ **1º BACKUP AGORA:** com o isolamento validado, exporte a configuração do OpenWrt (**LuCI → System → Backup / Flash Firmware → Generate archive**). Isso gera um `backup-*.tar.gz` — guarde-o num lugar seguro fora do roteador. *(Repita este backup a cada alteração de regra — ver Bloco 14.)*

‖ PONTO DE VIRADA

A rede está pronta, validada **e com backup**. **Só agora** você pode limpar os endpoints e, em seguida, as contas. Não cruze esta linha antes do teste passar.

BLOCO 9 — Sanitização dos endpoints

> 🟢 Simples, mas 🔴 **destrutivo e irreversível**. Confirme que não há nada para salvar antes de apagar.

- ☐ **Notebook:** pendrive de instalação feito num **PC limpo** (não no seu hardware atual). Na tela de partições, **excluir TODAS** (inclusive Recovery) e instalar na área não alocada.
- ☐ **Celular Android:** Factory Reset pelo recovery/bootloader.
- ☐ **Câmera Tapo:** reset físico ~10s.
- ☐ **Smart TV:** Factory Reset interno.

> A partir daqui, use **somente um dispositivo recém-formatado** para os blocos de contas.

BLOCO 10 — E-mail principal (a raiz de tudo)

- ☐ Senha nova, longa e única.
- ☐ **Encerrar todas as sessões ativas** ("sair de todos os dispositivos").
- ☐ **Apagar regras de encaminhamento/filtros** que você não criou. 🔴 *(vetor mais ignorado de todos)*
- ☐ Revisar "atividade recente / dispositivos" → remover desconhecidos.
- ☐ Ativar **2FA por app autenticador** (não SMS).
- ☐ Revisar e **revogar apps OAuth / terceiros** não reconhecidos.

BLOCO 11 — Gerenciador de senhas

> ✦ Vem **antes** do Bloco 12 de propósito: é com ele que você vai gerar as senhas das próximas contas.

- ☐ Instalar Bitwarden/1Password **no dispositivo limpo**.
- ☐ **Senha-mestra nova, forte, única.**
- ☐ Ativar 2FA no gerenciador.
- ☐ Usá-lo para gerar as senhas dos próximos blocos.

BLOCO 12 — Demais contas (ordem por dano)

Para CADA conta: **senha nova → encerrar sessões → 2FA → revogar OAuth → checar dispositivos.**

- ☐ **Banco / cartões.**
- ☐ **Microsoft / Azure** (trabalho/DevOps).
- ☐ **GitHub** → 🟢 *(confortável pra você)* além da senha, **regerar chaves SSH e Personal Access Tokens** — não basta trocar a senha, os tokens antigos continuam válidos se não forem revogados.
- ☐ **Nuvem** (Google Drive / OneDrive / Dropbox).
- ☐ **Redes sociais e demais logins.**

BLOCO 13 — Arquivos na nuvem (risco silencioso)

> ● **Tratar tudo como sujo até prova em contrário. NÃO ressincronizar a pasta inteira.**

- ☐ Acessar a nuvem pela **interface web** (não reinstalar o cliente de sync ainda).
- ☐ Revisar **compartilhamentos**: remover "qualquer pessoa com link" e contas estranhas.
- ☐ Revisar **permissões de apps** sobre a nuvem.
- ☐ Recuperar arquivos **seletivamente** — priorizar passivos (textos, PDFs, fotos).
- ☐ **Desconfiar de:** `.exe` / `.msi`, instaladores, scripts (`.js` / `.bat` / `.ps1` / `.vbs`), macros (`.docm` / `.xlsm`).
- ☐ Críticos e duvidosos → **VirusTotal** antes de abrir.
- ☐ Só religar a sincronização depois da pasta revisada.

BLOCO 14 — Rotina e detecção de reincidência

- ☐ **Backup das regras de firewall** (arquivo `.tar.gz` gerado no LuCI → System → Backup) — o **1º** já foi feito no Bloco 8; **repita a cada alteração** de política.
- ☐ Auditar tabelas de tráfego no LuCI periodicamente.
- ☐ Manter pacotes do OpenWrt atualizados.
- ☐ Sempre **VLAN 20 = trabalho**, **VLAN 30 = lazer/casa**.

Sinais de que algo voltou:
- ☐ E-mails de novo login / códigos 2FA não solicitados.
- ☐ Regras de encaminhamento apagadas que **reaparecem**.
- ☐ No **syslog do OpenWrt**, dispositivo "telefonando" para destinos estranhos.

Se reincidir, é uma de 3 causas: dispositivo não limpo, credencial não rotacionada, ou OAuth/encaminhamento esquecido. → Volte ao bloco correspondente.

Resumo da espinha dorsal (cole na parede)

Comprar → NOVO Ensaiar OpenWrt (e limpar o roteador) → Cortar fibra → Extrair GPON → ONT → Flash → WAN (VLAN10 → MAC → PPPoE → testar) → VLANs → mDNS → UPS → TESTAR rede + 1º BACKUP → Formatar aparelhos → E-mail → Gerenciador de senhas → Demais contas → Nuvem → Rotina.

A linha que nunca se cruza: **só mexer nas contas (Bloco 10+) depois da rede validada e com backup (Bloco 8) e dos aparelhos limpos (Bloco 9).**

Mudanças da V12 → V13

- ● **Bloco 0.5:** adicionada a **higiene do roteador de ensaio** — re-flash limpo ou reset antes do uso definitivo, para não arrastar config/exposição do ambiente sujo. Pesquisa de dúvidas movida para o 4G/5G (não usar a rede da Vivo).
- **Bloco 4:** corrigida a ambiguidade do "(se ainda não fez)" — agora **só o flash** é opcional; **acessar o LuCI e conectar a ONT são sempre necessários** (sub-bloco 4.2 separado). Nota sobre o rótulo do campo de MAC variar no DSA.
- ● **Bloco 8:** teste de isolamento **completado** — agora valida explicitamente 30→40 (funciona), 40→30 (falha), 50→qualquer (falha) **e a invisibilidade da VLAN 20 ao mDNS** (lacuna que o Bloco 6 prometia e não era testada).

- **Backup movido para o Bloco 8:** o 1º backup passa a ser feito **assim que o isolamento é validado** (antes ficava só no Bloco 14, depois de formatar tudo — risco de perder a config no meio do caminho).
- **Terminologia corrigida:** OpenWrt/LuCI exporta `.tar.gz` **(tarball)**, **não XML**. Removidas as menções a "exportação XML" (herança do pfSense das versões antigas).
- ▲ **Bloco 2:** reescrito o aviso para deixar claro que ler credenciais GPON locais **não viola a Regra nº 3** (que trata de *contas*); o cuidado com o .txt continua.
- ✓ **Regra nº 4 / resumo:** atualizado para incluir a limpeza do roteador de ensaio e o "1º backup" na espinha dorsal.

> ✦ **As correções da V12 que continuam valendo:** Bloco 0.5 (ensaio a seco), mapa de dificuldade, ordem VLAN10→MAC→PPPoE no Bloco 4, alertas de SLID bloqueado e DSA vs. tutoriais antigos.